Capa do Artigo

Título em Português: Mecanismos de Segurança e Conformidade com a LGPD no sistema Web StudyFlow.

Título em Inglês: Security Mechanisms and LGPD Compliance in the StudyFlow Web System.

Título em Espanhol: Mecanismos de Seguridad y Cumplimiento de la LGPD en el Sistema Web StudyFlow.

Autores

Nome	E-mail	ORCID
João Vitor Rodrigues [1*]	joaovr724@gmail.com	https://orcid.org/0009-0009-2615-0852
Higor de Castro Venancio da Silva [1]	higorcastro142@gmail.com	https://orcid.org/0009-0006-9323-2880

* Autor Correspondente

Instituições

1. Universidade de Mogi das Cruzes, Mogi das Cruzes, São Paulo, Brasil.

Informações

Categoria de Publicação: Resumo.

Tipo de Publicação: Pesquisa.

Área do Conhecimento: Ciências Exatas e da Terra.

Título em Português

Mecanismos de Segurança e Conformidade com a LGPD no sistema Web StudyFlow.

Resumo

Os sistemas web que armazenam dados pessoais estão sujeitos a ataques de força bruta, vazamento de dados e uso indevido de sessões, exigindo mecanismos de defesa adequados e alinhados com a LGPD. Objetivo: Apresentar os mecanismos de segurança do StudyFlow, sistema web de gestão de estudos, contemplando autenticação robusta, proteção de dados em trânsito e em repouso, logs inalteráveis e conformidade com a LGPD. Métodos: Pesquisa aplicada, desenvolvida na Universidade de Mogi das Cruzes, entre agosto e outubro de 2026. Arquitetura cliente-servidor, front-end em React e back-end em Java com Spring Boot, senhas protegidas com BCrypt e salt, hospedado na Vercel e no Render, com criptografia em repouso, mapeamento de finalidade e minimização dos dados coletados (nome e e-mail). A amostra foi composta pelos casos de teste documentados nas evidências funcionais, com os fluxos de cadastro, login, 2FA, recuperação de senha, alteração de logs e consentimento LGPD. Foi analisado o tempo de bloqueio após muitas tentativas de login, validade de tokens e códigos de verificação, e a integridade dos registros dos logs. Os testes foram feitos com o Postman, o front-end e consultas diretas no PostgreSQL. A análise foi qualitativa, comparando o comportamento esperado com o observado. Resultados: Observou-se bloqueio da conta após cinco tentativas de login, a invalidação do token após o logout, o redirecionamento de HTTP para HTTPS, a recusa de alteração dos logs pelo próprio banco de dados, e a visualização e exclusão dos dados pelo usuário, com acesso ao sistema condicionado ao aceite de termo de consentimento. Conclusão: Os mecanismos atenderam ao objetivo proposto, evidenciando o funcionamento da autenticação em duas etapas, da comunicação cifrada por TLS, da auditoria protegida contra alteração e da conformidade com a LGPD. Recomenda-se a adoção de HSTS para eliminar a requisição HTTP inicial não cifrada.

Palavras-chave

Palavras-chave: Segurança de aplicações web; Autenticação em dois fatores; Criptografia; Auditoria de logs; LGPD.

Title in English

Security Mechanisms and LGPD Compliance in the StudyFlow Web System.

Abstract

Web systems that store personal data are subject to brute-force attacks, data leakage, and improper use of sessions, requiring appropriate defense mechanisms aligned with the Brazilian General Data Protection Law (LGPD). Objective: To present the security mechanisms of StudyFlow, a web-based study management system, including robust authentication, protection of data in transit and at rest, immutable logs, and compliance with the LGPD. Methods: Applied research conducted at the University of Mogi das Cruzes between August and October 2026. The system follows a client-server architecture, with a React front-end and a Java back-end using Spring Boot, passwords protected with BCrypt and salt, and hosting on Vercel and Render, with encryption at rest and minimization of collected data, limited to name and email. The sample consisted of test cases documented in the system's functional evidence, involving registration, login, two-factor authentication, password recovery, log alteration, and LGPD consent. The analyzed variables were the account lockout time after repeated login attempts, validity of tokens and verification codes, and integrity of log records. Tests were performed using Postman, the front-end, and direct queries in PostgreSQL. The analysis was qualitative, comparing expected behavior with observed behavior. Results: Account lockout after five login attempts, token invalidation after logout, HTTP-to-HTTPS redirection, prevention of log alteration by the database itself, and user access to view and delete personal data were achieved, with system access conditioned on acceptance of the consent term. Conclusion: The mechanisms met the proposed objective, demonstrating the effectiveness of two-factor authentication, TLS-encrypted communication, immutable auditing, and compliance with the LGPD. The adoption of HSTS is recommended to eliminate the initial unencrypted HTTP request.

Keywords

Keywords: Web application security; Two-factor authentication; Encryption; Audit logs; LGPD.

Título en Español

Mecanismos de Seguridad y Cumplimiento de la LGPD en el Sistema Web StudyFlow.

Resumen

Los sistemas web que almacenan datos personales están sujetos a ataques de fuerza bruta, filtraciones de datos y uso indebido de sesiones, lo que exige mecanismos de defensa adecuados y alineados con la Ley General de Protección de Datos de Brasil (LGPD). Objetivo: Presentar los mecanismos de seguridad de StudyFlow, un sistema web de gestión de estudios, contemplando autenticación robusta, protección de datos en tránsito y en reposo, registros inmutables y cumplimiento de la LGPD. Métodos: Investigación aplicada, desarrollada en la Universidad de Mogi das Cruzes entre agosto y octubre de 2026. El sistema utiliza arquitectura cliente-servidor, front-end en React y back-end en Java con Spring Boot, contraseñas protegidas con BCrypt y salt, alojamiento en Vercel y Render, cifrado en reposo y minimización de datos recopilados. La muestra incluyó casos de prueba de registro, inicio de sesión, autenticación de dos factores, recuperación de contraseña, modificación de registros y consentimiento de la LGPD. Se analizaron el bloqueo tras intentos de inicio de sesión, la validez de tokens y códigos de verificación y la integridad de los registros. Las pruebas se realizaron con Postman, el front-end y consultas directas en PostgreSQL. El análisis fue cualitativo, comparando el comportamiento esperado con el observado. Resultados: Se logró el bloqueo de la cuenta después de cinco intentos, la invalidación del token tras el cierre de sesión, la redirección de HTTP a HTTPS, el rechazo de modificaciones de los registros por la base de datos y la visualización y eliminación de datos por el usuario, con acceso condicionado al consentimiento. Conclusión: Los mecanismos cumplieron el objetivo propuesto, demostrando la eficacia de la autenticación en dos etapas, la comunicación cifrada mediante TLS, la auditoría inmutable y el cumplimiento de la LGPD. Se recomienda adoptar HSTS para eliminar la solicitud HTTP inicial no cifrada.

Palabras clave

Palabras clave: Seguridad de aplicaciones web; Autenticación de dos factores; Cifrado; Registros de auditoría; LGPD.

Referências

1. Pimenta AMS, Quaresma RFC. A segurança dos sistemas de informação e o comportamento dos usuários. J Inf Syst Technol Manag. 2016;13(3):533-52. doi:10.4301/S1807-17752016000300010.
2. Alves ARN, Alves JMH, Vasconcelos IO, Cruz CAB. Fator humano na segurança da informação: um mapeamento dos comportamentos de risco no ambiente digital. Texto Livre. 2024;17:e51184. doi:10.1590/1983-3652.2024.51184.
3. Viana S, Silva RF, Pavón J, Laine JM. Segurança no desenvolvimento de aplicações web com a qualidade dos dados. Rev Sist Comput. 2013;3(2):93-104.
4. Galegale NV, Fontes ELG, Galegale BP. Uma contribuição para a segurança da informação: um estudo de casos múltiplos com organizações brasileiras. Perspect Cienc Inf. 2017;22(3):75-97. doi:10.1590/1981-5344/2866.
5. Almeida SCD, Soares TA. Os impactos da Lei Geral de Proteção de Dados - LGPD no cenário digital. Perspect Cienc Inf. 2022;27(3):26-45. doi:10.1590/1981-5344/25905.
6. Paula APO, Oliveira GW, Macedo SS, Costa AFJ, Piffer DM. LGPD por design: privacidade e proteção de dados em projetos de software. Observ Econ Latinoam. 2024;22(6):e5520. doi:10.55905/oelv22n6-258.
7. Souza WG, Pinto GS. A utilização do Vue.js com uma API REST em Spring Boot. Rev Interface Tecnol. 2020;17(2):155-67. doi:10.31510/infa.v17i2.904.
8. Provos N, Mazières D. A future-adaptable password scheme. In: Proceedings of the 1999 USENIX Annual Technical Conference; 1999 Jun 6-11; Monterey, CA. Berkeley: USENIX Association; 1999. p. 81-92.
9. Galindo Junior EA, Rocha RD, Maciel RS. Desenvolvimento de API REST com Spring Boot. Rev Cient UniRios. 2021;15(29). Disponível em: https://www.publicacoes.unirios.edu.br/index.php/revistarios/article/view/102
10. Brasil. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD) [Internet]. Brasília: Presidência da República; 2018 [citado 2026 set 30]. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709compilado.htm